

INFORMATION SECURITY (IS)

Information: Data that has been processed in a way that gives it meaning and value

Information security: Protection of the integrity, confidentiality and availability of information

Non-repudiation: Prevents parties from denying their actions

Accountability: Ability to trace actions back to a person

Authentication: Verifies the identity of a user or system

Authorization: Determines actions an entity is allowed to do

Access control: Restrict access to resources based on roles

Security policy: A rule/expectation for protecting information

Compliance: Adherence to laws, regulations, and standards

Types of information: Personal, business, financial, intellectual, system

Components of an Information System (IS): Software, Hardware, Data, People, Procedures, Networks

Bottom-Up: Implementations happen before policies

Top-Down: Initiated by management, more effective

McCumber cube: x: CIA (what), y: Information states (where), z: Control (how)

(C)onfidentiality: Prevent unauthorized access to info

(I)ntegrity: Protect reliability and correctness of information

(A)vailability: Ensure uninterrupted access to information

Information states: In storage, in transit, in use

Control: A measure designed to reduce the potential risk of an attack by eg. **Policy, Education, Technology**

(S)poofing: Pretending to be someone else

(T)ampering: Unauthorized data modification or altering

(R)epudiation: Denying actions without proof

(I)nformation disclosure: Exposing sensitive information

(D)enial of service: Making systems or services unavailable

(E)levation of privilege: Gaining unauthorized rights

THREAT CATEGORIZATION

SOCIAL ENGINEERING

Manipulating people to reveal confidential information

Phishing: Forged emails impersonating legitimate entities

Spear Phishing: Targeted phishing to specific individuals

Vishing: Voice-based phishing over phone or video calls

Smishing: SMS / Text-based phishing

SOFTWARE ATTACKS

Exploiting vulnerabilities in software to gain access to a system or steal data

Virus: Malware that attaches to programs and spreads

Worms: Self-replicating malware that spreads over a network

Trojan Horse: Malicious sw disguised as legitimate apps

Ransomware: Encrypts victim data, asks payment to restore

Rootkits: Stealthy tools that hide malicious activity and maintain privileged access

DENIAL OF SERVICE

Overloading one or multiple systems to make it unavailable

DoS: Single source denial of service attacks

DDoS: Dos performed by multiple attackers/devices

Botnet: Network of compromised devices controlled by an attacker and used to together to flood a target with traffic

SYN-Flood Attack: Sending many TCP connection requests without completing them

Reflection Attack: Attacker spoofs victim's IP, sends requests to a service so that it sends (many) replies to victim

WEB APPLICATION ATTACKS

Exploiting vulnerabilities in websites/servers hosting websites

SQL Injection: Insert malicious SQL commands into an input

Cross-Site Scripting (XSS): Inject malicious scripts into website that execute in users' browsers to steal data

Cross-Site Request Forgery (CSRF): Trick logged-in user's browser into sending reqs to a webapp on attacker's behalf

Broken Authentication: Weak auth mechanisms allow attackers to gain unauthorized access (password/session)

PASSWORD / AUTHENTICATION ATTACKS

Attempting to bypass or compromise login systems to gain unauthorized access

Rainbow Table Attacks: Precomputed hash lookup tables to reverse weakly hashed passwords back into plaintext

Password Spraying: Trying a few common passwords like "password" across many accounts to avoid lock-timeouts

Credential Stuffing: Using leaked credentials from previous breaches to attempt logins on other services

Brute Force Attack: Repeatedly try many username & password combinations until they gain access to an account

PHYSICAL ATTACKS

Bypassing technical controls by accessing physical infrastructure directly

Theft of devices: Physically steal hardware to gain direct access to stored data, credential, internal systems, ...

Hardware tampering: Modify/implant malicious components in to intercept data, bypass security, or disrupt operations

Power disruption: Interrupt or manipulate power supply impacting availability and business continuity

Environmental damage: Environmental events that damage infrastructure, causing data loss, downtime, ...

INFORMATION SECURITY MANAGEMENT (ISM)

TODO:
notes 12

Information security governance: System by which IS strategy is controlled to ensure that it supports business objectives, manages risk appropriately, and complies with legal and other regulatory requirements. (what)

Information Security Management System (ISMS): Framework used to manage and protect assets through policies, processes and controls (how)

Enterprise Information Security Policy (EISP): Information security policy that sets the strategic direction and scope for all an organization's security efforts

Risk Management Process: Definition of processes to identify assets, analyze threats and evaluate risk

Security Awareness and Training: Educational programs to ensure employees understand their security responsibilities

Monitoring, Measurement and Audits: Ongoing evaluation of control effectiveness and ISMS performance

POLICY

Practices: Ex. actions that illustrate compliance with policies

Policy: Instructions that dictate certain behavior within an org

Standard: Details of what must be done to comply with policy

Guidelines: Non-mandatory recommendations (reference)

Procedures: Step-by-step instructions designed to assist employees in following policies

De jure standard: Formally evaluated and approved by a formal standards organization

De facto standard: Widely adopted/accepted by public group

TODO:
notes 14,15

RISK ANALYSIS

Identify Assets → Identify Threats → Identify Vulnerabilities → Assess Likelihood → Assess Impact → Determine Risk Level

Asset: Item of value belonging to an organization, eg: Information: Customer data, intellectual property, code

Technical: Services, applications, databases, networks

Physical: Servers, devices, facilities, infrastructure

Human: Employees, administrators, contractors

Business Process: Critical operational workflows

Threat: An event or action with the potential to cause harm by exploiting a vulnerability, eg: power outage, vishing

CLASSIFYING ASSETS

Public: Information that can be shared without risk

Internal: Information for organization internal use only

Confidential: Sensitive info, could cause harm if disclosed

Restricted: Highly sensitive, strictly limited, strongly protected

SECURITY CONTROLS

Administrative/Management Controls: Policies, procedures, security training, security governance

Technical / Logical Controls: Firewalls, encryption, access control systems, system hardening

Physical Controls: Physical locks, surveillance cameras, secure access badges, turnstiles

Preventive Controls: Stop incidents before they occur. eg. Firewalls, access control, encryption

Detective Controls: Identify incidents when they occur. eg. Intrusion detection, log monitoring, SIEM, CCTV

Corrective Controls: Limit damage, restore systems after an incident. eg. Backups, system restore, incident response

Deterrent Controls: Discourage malicious behavior. eg. Warning banners, monitoring notices, disciplinary policies

Compensating Controls: Reduce risk when a primary control cannot be implemented. eg. Network isolation, layered security, alternative safeguards

Business continuity: Ensures critical operations continue during disruptions. Objectives: maintain operations, minimize impact, protect assets, recover fast

SECURITY AND AWARENESS TRAINING

1) **Awareness:** basic information, what

2) **Training:** detailed knowledge, how

3) **Education:** depth of knowledge, why

GAP ANALYSIS

Define target framework → Assess curr state → Identify gaps, assess risk → Eval, prioritize gaps → Create remediation plan

SECURITY FRAMEWORK

NIST Cybersecurity Framework: Framework for managing cyber risk: Identify, Protect, Detect, Respond, Recover

CIS Controls: Defines 18 practical technical security controls

THREATS

Attack: Act that intends to damage, steal or degrade assets

Vulnerability: A weakness in a system that can be abused

Exploit: A method used to take advantage of a vulnerability

Risk: The likelihood of a threat exploiting a vulnerability and the potential harm that could cause = Vulnerability + Threat

Threat vector: Path, method, or delivery mechanism that a threat uses to reach an asset and exploit a vulnerability

Attack surface: Sum of threat vectors that hackers can use to carry out a cyberattack.

RISK MANAGEMENT (RM)

The process of identifying, assessing, prioritizing and mitigating threats to an asset from an organisation.

Risk management process: Implementation, analysis, evaluation of the risk management framework (doing).

Risk assessment: The identification, analysis, and evaluation of risk as initial parts of risk management.

Risk treatment & Risk Owner: The application of safeguards or controls to reduce the risks to an organization's information assets to an acceptable level.

1) **Risk identification:** Where and what is the risk?

2) **Risk analysis:** How severe is the current level of risk?

3) **Risk evaluation:** Is the current level of risk acceptable?

4) **Risk treatment:** What do I need to do to bring the risk to an acceptable level?

Risk management framework: Structure of the strategic planning and design of risk management efforts (planning).

1) **Executive Governance & Support:** Support from management and users.

2) **Framework Design:** Defining the methods and risk appetite strategy.

3) **Framework Implementation:** Rollout of the plan (through → RM process).

4) **Monitoring & Review:** How effective is the entire system?

5) **Continuous Improvement:** Continuous adaption to new, or existing threats.

Risk appetite (strategic): The quantity of risk that organizations are willing to accept, to achieve their goals

Risk tolerance (specific): The acceptable risk organizations are willing to accept for a specific asset

Residual risk: Remaining risk after controls were applied

TODO:
slides 17,19 (notes 19,20), risk identification, risk analysis

Common Vulnerabilities and Exposures (CVE): Standard identification number for vulnerabilities

Common Vulnerability Scoring System (CVSS): Severity scores for vulnerabilities based on CIA

QUANTITATIVE RISK ANALYSIS

1) Assign Asset Value (AV)

1) Identify the organization's information assets.

2) Classify them.

3) Categorize them into useful groups.

4) Prioritize them by overall importance.

2) Calculate Exposure Factor (EF)

– percentage of loss that an organization would experience if a specific asset is violated by a realized risk

3) Calculate single loss expectancy (SLE)

– Exact amount of loss if an asset were harmed by a threat

– $SLE = AV \times EF$

4) Assess the annualized rate of occurrence (ARO)

– Expected occurrence frequency of a threat within a year

5) Derive the annualized loss expectancy (ALE)

– possible yearly cost of all instances of a realized threat against an asset

– $ALE = SLE \times ARO$

6) Perform cost/benefit analysis of countermeasures

TODO:
ALE with safeguards, risk evaluation, risk treatment, mitigation (notes 22,23)

IDENTITY & ACCESS MANAGEMENT (IAM)

Provisioning and protecting digital ids & access permissions

Subject: Active entity that accesses a passive object. users, programs, processes, services, computers

Object: Passive entity that provides information to subjects. files, databases, computers, programs, services, printers

Physical controls: To prevent, monitor, or detect direct contact with systems: guards, fences, motion detectors

Technical or logical controls: To manage access and provide protection for resources. auth, encryption, ACL

Administrative controls: Policies and procedures. hiring practices, background checks, security training

Identification: Claiming an identity, eg. typing a username

Authentication: Verifying validity of claimed id, eg. password

1) Something you know, eg. password

2) Something you have, eg. smartcard

3) Something you are/something you do, eg. biometrics

4) Somewhere you are / aren't (secondary factor)

Basic Authentication: Username/pw transmitted in the clear

One Time Passwords: Basic auth but used only once

Challenge / Response: Password and one-time challenge

Anonymous Key Exchange: Exchange credentials over unauthenticated secure channel, eg. diffie-hellmann

Zero-Knowledge Password Proofs: Does not permit offline-based password attacks

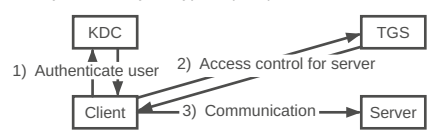
Server Certificates + User Authentication: Transmit user password over unilaterally authenticated secure channel

Mutual Public Key Authentication: Bilateral use of public key signatures

Multifactor Auth: Using two or more factors

KERBEROS

Uses symmetric key encryption (DES)



Principal: A Kerberos participant

Principal's Master Key: Long-term secret between the principal and KDC. Used to en-/decrypt authentication tickets.

Kerberos Ticket: Temporary credential for network services

Authentication Server (AS): Verifies client, gives TGT

Ticket Granting Server (TGS): Grants services, gives ST

Ticket Granting Ticket (TGT): Given by the AS

Service Ticket (ST): Given by the TGS

Key Distribution Center (KDC): Verifies & manages auth credentials, distributes session keys to users and services

RADIUS

Remote Authentication Dial-In User Service provides centralized Authentication, Authorization and Accounting (AAA)

1) User requests access from Network Access Server (NAS)

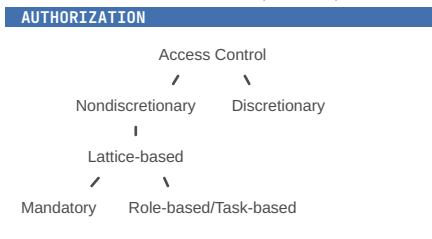
2) NAS prompts the RADIUS server for credentials

3) RADIUS server evaluates the request and returns one of:

- Access-Accept: User authenticated, NAS grants access
- Access-Reject: Invalid credentials, NAS denies access
- Access-Challenge: Server requires more info (MFA)

4) Connected: NAS sends Accounting-Request (log session)

Attack	Kerberos	RADIUS
Passive Password Sniffing		
Offline Brute Force Password Attack	X	X
Active Man-in-the-Middle Attack		X
Identity Theft on Server		
CA Compromise		X



Discretionary access control (DAC): Every object has an owner, the owner can grant or deny access (sharing drive)

Nondiscretionary access control (NDAC): Access controls that are implemented by a central authority (HIPAA/DSG)

Lattice-based access control (LBAC): Assigns users a matrix of authorizations for particular areas

Mandatory access control (MAC): Labels applied to both subjects and objects (classified documents ↔ glowies)

Role-based access control (RBAC): Privileges are tied to a role or job (project info ↔ project manager)

Task-based (TBAC) access control: Privileges are tied to a task (access to server room ↔ technician's time slot)

Auditing: A subject's actions are tracked and recorded

Accounting: Consumption of resources by a subject is measured, metered, and collected.

TODO:
shorten all this below

Salting: Adds unique random value to each password before hashing, prevents identical passwords from producing identical hash values

Access Aggregation Attacks (passive attack): Collecting multiple pieces of nonsensitive information and aggregating them to learn sensitive information (Reconnaissance attack)

Password Attacks (brute-force attack):

- Online: Attacks against online accounts
- Offline: to steal an account database and then crack the passwords.

Dictionary Attack (brute-force attack): An attempt to discover passwords by using every possible password in a predefined database

Birthday Attack (brute-force attack): Finding collisions.

- MD5 is not collision free
- SHA-3 is considered safe against birthday attacks and collisions

Sniffer Attacks: Application that captures traffic traveling over the network

- Encrypt all sensitive data
- Use onetime passwords (OTP)
- Protect network devices with physical security

CRYPTOGRAPHY

Ciphertext/Cryptogram: Encrypted message
Cipher: Encryption algorithm. Set of rules for en-/deciphering
Key/Cryptovariable: Usually a very large binary number
Key space: Range of numbers from 0 to 2^n , where n is the bit size of the key. A 128-bit key is $\in \{0, ..., 2^{128}\}$
One-Way Functions: Easily produces output values but makes it impossible to retrieve the input values
Reversability: Being able to undo the operation of encryption
Nonce: Must be a unique number each time it is used. Used to make sure that a key is not re-used twice. The nonce is public, whereas the (shared) key is private
Initialization vector (IV): Random bit string, same length as the block size and is XORed with the message to create unique ciphertext every time same message is encrypted
Steganography: Embedding secret messages within content
Objectives: Confidentiality (Privacy), Integrity, Authentication, Non-repudiation
Kerkhoff's Principle: Security stems from the secrecy of the key and not the secrecy of the algorithm
Shannon's Principles:
 Confusion: Relationship between the plaintext and the key is complicated. S-Box, substitution
 Diffusion: Change in plaintext results in multiple changes spread throughout the ciphertext. P-Box, permutation
SP-Network: Repeated substitution and permutation
One-Time-Pad (OTP): XORing all bytes with same size OTP
Hashing: Maps data to fixed-size output. Should be: random, diffused, fast, deterministic, irreversible, collisionless
Password storage: Prefer slow hash functions (SHA-256)
Summarizing data: Prefer fast hash functions (argon2)
HMAC: Hash based MAC, splits a key in two and hashes twice, not vulnerable to length extension attack
SHA-1: Insecure, fast
SHA-2: 256/512-bit variants, current standard, secure
SHA-3: (KECCAK), flexible
KMAC 128/256: SHA-3 based KECCAK MAC
bcrypt: Salted, GPU-resistant
Argon2: Highly secure, configurable
AES: Advanced Encryption Standard (SP-Net). XOR, Sub-Bytes, ShiftRows, MixColumns

SYMMETRIC CRYPTOGRAPHY

Relies on shared secret key, distributed to all members participating in the communications

Stream ciphers: Approximate a one-time pad by generating an infinite pseudo-random keystream, work on messages of any length, nonce guarantees uniqueness, fast, no guaranteed integrity
Block ciphers: Take an input of a fixed size and return an output of the same size, use confusion and diffusion (SP-Network) $\Rightarrow$ AES

TODO:
S-Box, P-Box (slides 39)

Electronic Code Block (ECB):

TODO:

Cipher Block Chaining (CBC):

TODO:

Counter Mode (CTR):

TODO:

ASYMMETRIC CRYPTOGRAPHY

Relies on mathematically linked key pairs. $n \in \mathbb{N} \setminus \{0\}, z \in \mathbb{Z}$
Public-key enc: $\text{pubk } (e, n)$ encrypt, $\text{privk } (d)$ decrypt
Digital signing: $\text{privk } (d)$ sign, $\text{pubk } (e, n)$ verify
Discrete logarithm: $f(g, a, p) = g^a \bmod p$ (Diffie-Hellman)
Primitive root:

TODO:

Factoring: $f(p, q) = p \cdot q$ (RSA)

Euler's Theorem: $\text{gcd}(z, n) = 1 \Rightarrow z^{\varphi(n)} \equiv 1 \bmod n$
Totient:
 $\mathbb{Z}_n^* = \{x \in \mathbb{Z}_n \mid x \text{ has a multiplicative inverse in } \mathbb{Z}_n\}$
 $\varphi(n) = \text{Nr. of elements in } \mathbb{Z}_n \text{ with mult. inv.}$
 $= \text{Amount of Numbers } 1 \leq q \leq n \text{ with } \text{gcd}(q, n) = 1$
 $= |\mathbb{Z}_n^*|$

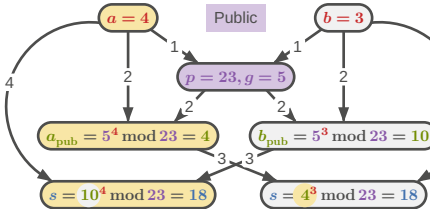
- $n \in \mathbb{N}$ prime $\Rightarrow \varphi(n) = n - 1$
- $n \in \mathbb{N}$ prime, $p \in \mathbb{N} \setminus \{0\} \Rightarrow \varphi(n^p) = n^{p-1} \cdot (n - 1)$
- $m, n \in \mathbb{N} \setminus \{0\}, \text{gcd}(m, n) = 1 \Rightarrow \varphi(n \cdot m) = \varphi(n) \cdot \varphi(m)$

RSA: Rivest–Shamir–Adleman: Signing, use DH for Encryption. Weak for short messages, add OAEP
1) Choose two prime numbers p, q
2) Calculate $n = p \cdot q$
3) Calculate $\varphi(n) = (p - 1)(q - 1)$
4) Choose a, b , so that $a \cdot b \equiv 1 \bmod \varphi(n)$
5) Forget $p, q, \varphi(p \cdot q)$

Public key is now n, b , private key is n, a

– Encrypt: $z = e^a \bmod n$
– Decrypt: $c = z^b \bmod n = e^{a^b} \bmod n$
OAEP: Padding, introduces IV and hashes it
PSS: Probabilistic Signature Scheme: Hash, Salt, Pad, RSA
DSA: Digital Signature Algorithm
DSS: Digital Signature Standard
DH: Diffie Hellman, share secret over insecure channel

- Agree on **public parameters** (prime and generator)
- Combine **private key** with **the parameters**
- Send resulting **public keys** to each other
- Combine other **pubkey** with **priv key** to get shared **secret**



ECC: Elliptic Curve Cryptography

TODO:
ECDSA: Elliptic Curve Digital Signature Algorithm
ECDH: Elliptic-Curve Diffie Hellman
ECDHE: Elliptic Curve Diffie-Hellmann Ephemeral
Perfect forward secrecy: Ephemeral DH KEX, forces new key exchange for every new session (refreshing website)

TRANSPORT LAYER SECURITY (TLS)

TODO:
handshake

AEAD: Authenticated Encryption with associated data



GCM: Galois Counter Mode $\rightarrow$ Message Authentication Code
PUBLIC KEY INFRASTRUCTURE (PKI)

A set of roles, policies, hardware and software needed to manage digital certificates and public-key encryption

TODO:
explanations

Subscriber $\xrightarrow{\text{CSR}}$ RA $\rightarrow$ CA $\rightarrow$ VA
RA: Registration Authority, validates CSR
CP: Certificate Policies
CPS: Certificate Practice Statements
CA: Certificate Authority, trusted certificate issuer
CSR: Certificate Signing Request (creates)
CRL: Certificate Revocation List (signs)

VA: Validation Authority, validates integrity of certificates
TSA: Time Stamp Authority
Subscriber: Client / Certificate holder
HPKP: Certificate pinning
Truststore: Central (private) storage for certificates
Keystore: Central (private) storage for private keys
Hybrid cryptosystem: Var. methods for optimal use-cases
 – Hashing: Digital fingerprint
 – Symmetric cryptography: Bulk encryption
 – Asymmetric cryptography: Signing/exchanging keys
Cipher suites: **enc_key_signature_WITH_bulk-enc_mac**
 TLS_DHE_RSA_WITH_AES_128_GCM_SHA256
OCSP: Certificate Status Protocol
CT: Certificate Transparency

TODO:
illustrate CSR procedure

E-MAIL

MIME: Multipurpose Internet Mail Extensions
S/MIME: Secure MIME (signatures + encryption)

TODO:
notes 50-55

CYBER KILL CHAIN

A model developed by Lockheed Martin in 2011, adapted from a military concept.

- Reconnaissance: Gather information on the target
 – Social media, DNS Lookup, Legal info
- Weaponization: Construct custom weapon to attack target
 – Exploit: Office macro execution, malicious PDF
 – Payload: Remote Access Tool, Ransomware, Spyware
 – Weapon: Phishing Email, Crafted Network Request
- Delivery: Transmit the weapon to the target
 – USB Drops, drive-by downloads, phishing mails
- Exploitation: Vulnerability is triggered or the target tricked
- Installation: Establish persistence, install backdoors
 – Scheduled tasks, startup folders
- Command & Control (C2): Compromised host connects to the attacker
 – DNS tunneling, HTTPS to legitimate-looking domain
- Actions on Objectives: Exfiltration, encryption, sabotage, lateral movement

Beaconing: Most C2 traffic beacons: small periodic checks, often jittered, tiny in volume but constant in rhythm

TODO:
breaking the chain

MITRE ATT&CK: Matrix of 14 tactics, hundreds of techniques
INCIDENT RESPONSE

ESCALATION PATH

Event: Any observable occurrence in a system. A user logs in, a file is created, a packet arrives. Most events are routine
Alert: Automated notification from a security tool that an event matched a detection rule and may warrant investigation
False positive: An alert or suspected adverse event that turns out to be benign

Adverse event: An event with possibly negative consequences, worth investigating
Incident: A confirmed adverse event that threatens the confidentiality, integrity, or availability of information assets
Data breach: An incident resulting in unauthorised access to or disclosure of protected data

PIPKIN'S INDICATORS

Possible: Weak signals, worth logging but not acting on alone
Probable: Strong signals, typically trigger investigation
Definite: Confirmed incidents, activate the IR plan

Classifier's dilemma:

True Positive	False Positive
False Negative	True Negative

DETECT AND RESPOND

"Prevent Everything": If the perimeter holds, we are safe
"Assume Breach" Mindset: Design for fast detection and fast containment, not just for prevention.

MTTD (Mean Time to Detect): Initial compromise - first alert
MTTR (Mean Time to Resp.): First alert - incident contained
Dwell Time (MTTD + MTTR): Total time attacker was active
SOC (Security Operations Centre): The always-on monitoring function. Runs the SIEM, triages alerts, drives day-to-day detection. (T1 triage, T2 investigation, T3 engineering).
CSIRT (Computer Security Incident Response Team): Handles confirmed incidents end-to-end. Often virtual, pulled together when needed: IT, legal, comm, mgmt
CERT (Computer Emergency Response Team): National or sector-level coordination bodies (e.g., GovCERT.ch)
In-House vs. Managed: Many organisations outsource SOC functions to an MSSP (Managed Security Service Provider). CSIRT responsibilities usually stay in-house.

NIST IR PROCESS

- Preparation: Policy, plan, team, tools, training
- Detection & Analysis: Spot signals, classify them
- Containment, Eradication & Recovery: Stop the bleeding, remove the attacker, restore services
- Post-Incident Activity: Lessons learned, feed back to Prep

TODO:
p.60+

This summary was created thanks to the motivation provided
by [turnstile](#) , [wisdom in chains](#) and [hands of god](#)